

QUESTION 1 – E-COMMERCE SERVER SECURITY

The e-commerce company is using an Apache/Linux server and has reported unauthorized transactions and suspicious HTTP requests. The presence of hidden directories, malicious input, an outdated server version and the absence of a Web Application Firewall increases the attack surface.

1. Possible attack vectors

The main attack vectors are outdated Apache software, exposed services, directory enumeration, malicious input handling, weak application validation and attacks through HTTP requests. Hidden directories may contain configuration files, backup files or administrative pages. If application inputs are not properly validated, an attacker may try injection or script-based attacks. Weak server configuration can also expose unnecessary services.

2. Kali Linux reconnaissance and vulnerability assessment

Testing should first be performed against an authorized lab copy or staging server. Nmap can be used to identify open ports and service versions. WhatWeb and curl can help identify web technologies and HTTP responses. Nikto can be used for basic web-server configuration checks, while Gobuster can be used to identify permitted directories and files.

Example commands for an authorized lab

```
nmap -sV -p 80,443 <LAB-IP>
```

```
whatweb http://<LAB-IP>
```

```
nikto -h http://<LAB-IP>
```

```
gobuster dir -u http://<LAB-IP> -w /usr/share/wordlists/dirb/common.txt
```

3. Controlled vulnerability validation

The findings should be reproduced only on the authorized test system. For example, an outdated Apache version can be compared with the vendor security advisories to determine whether a known vulnerability is relevant. Input fields should be tested with harmless validation strings to determine whether the application properly rejects unexpected data. Any exploitation should be stopped after confirming the vulnerability and should not be used to alter real transactions.

4. Layered defense

The server should be patched regularly and unnecessary services should be disabled. A WAF can provide another layer of filtering for malicious web requests. The application should use input validation, output encoding, secure session management and strong authentication. File permissions should follow least privilege. Logs should be collected centrally and monitored for suspicious requests. Regular vulnerability scans and penetration tests should be performed on staging environments.

QUESTION 2 – SQL INJECTION AND XSS

The financial services application has SQL injection and cross-site scripting risks. The error messages also reveal information about the database structure. These problems can allow unauthorized data access or execution of attacker-controlled browser scripts if they are not corrected.

1. Exploitation methodology

The assessment should begin by identifying input parameters that are used by the application. Burp Suite can be used as an intercepting proxy to observe and modify requests in an authorized test environment. SQL injection indicators can be checked using safe test values. SQLmap may then be used against a deliberately vulnerable lab endpoint to confirm whether a parameter is injectable. XSS testing should use harmless proof-of-concept input and should not target real users.

2. Burp Suite and SQLmap workflow

A typical workflow is to configure the browser to use Burp Suite, capture the request, identify the parameter under test and send the request to Repeater for controlled validation. If the application is specifically authorized for automated testing, SQLmap can be used on the identified test parameter. Results should be recorded with the affected parameter, evidence, risk and recommended fix.

3. CIA impact

Confidentiality can be affected if database information or customer records are exposed. Integrity can be affected if an attacker is able to modify application data. Availability may be affected if malicious database requests consume excessive resources or disrupt application operation. XSS can also affect confidentiality and integrity through unauthorized actions performed in a victim's browser.

4. Mitigation

The main SQL injection defense is parameterized queries or prepared statements. Database accounts should have only the permissions required by the application. Detailed database errors should not be displayed to users. For XSS, output encoding should be applied according to the output context and input validation should be used as an additional control. A suitable Content Security Policy can reduce the impact of some script injection cases. Security testing should be repeated after fixes.

QUESTION 3 – WPA2 EVIL TWIN AND MITM

The company uses WPA2-PSK wireless access and has experienced an Evil Twin attack. In this situation, an attacker creates a rogue access point that imitates the legitimate network name. A victim may connect to the fake network and unknowingly send traffic through the attacker-controlled access point.

1. How the Evil Twin attack works

The attacker creates a wireless network with a name similar to or identical to the legitimate SSID. If a client connects to the rogue network, the attacker may be able to observe or manipulate traffic that

is not protected by end-to-end encryption. Credential harvesting can occur when users are directed to a fake login page. WPA2-PSK does not by itself guarantee that a user has connected to the correct access point.

2. Aircrack-ng and Wireshark analysis

In an authorized wireless lab, Aircrack-ng tools can be used to inspect the wireless environment and analyze the security configuration. Wireshark can then be used to examine captured traffic for unusual DNS responses, unexpected destinations, repeated authentication attempts and other indicators. The analysis should focus on detection and evidence collection rather than attacking production wireless networks.

3. Weaknesses

Shared PSKs are difficult to control when many users know the same password. Weak passwords are more susceptible to guessing. Users may also trust an SSID name without verifying the network. Lack of certificate validation and lack of enterprise authentication can make rogue access points more effective.

4. Countermeasures

Use WPA3-Enterprise or WPA2-Enterprise with 802.1X where possible. Use strong unique credentials and certificate validation. Separate guest and internal networks. Monitor for rogue access points and unexpected BSSID changes. Train users not to enter credentials into unknown captive portals. Use HTTPS and VPN protection for sensitive traffic where appropriate.

QUESTION 4 – WEB APPLICATION THROUGH CORPORATE WI-FI

The internal employee management application is reachable through corporate Wi-Fi. The Wi-Fi password is weak and the web application has poor authentication and session management. A complete security assessment should therefore consider both the wireless and application layers.

1. Pentest chain

The assessment can begin with authorized wireless discovery and verification of the network security configuration. After obtaining approved access to the test network, the tester can identify the application host and enumerate the permitted services. Nmap can assist with service discovery, while Burp Suite or OWASP ZAP can be used to inspect application requests. Authentication, session handling and access-control rules should then be tested using dedicated test accounts.

2. Privilege escalation assessment

The tester should create accounts with different roles, such as employee and administrator, and verify that each account can access only its permitted functions. Attempts to access another user's records should be made only with test data. Session tokens should be checked for predictable behavior, improper expiration and missing authorization checks. Any confirmed issue should be documented without changing real employee information.

3. Defense-in-depth

The Wi-Fi should use strong authentication such as WPA2/WPA3-Enterprise and 802.1X. The application should enforce multi-factor authentication for sensitive roles, secure session cookies, short session lifetimes and server-side authorization checks. Network segmentation should prevent ordinary wireless clients from directly reaching sensitive internal systems. Logging and alerting should cover authentication failures, privilege changes and unusual access patterns.

QUESTION 5 – WIRELESS DEAUTHENTICATION ATTACK

A deauthentication attack abuses management frames to force wireless clients to disconnect from an access point. Repeated disconnections can prevent users from maintaining a stable connection and can therefore affect availability.

1. How deauthentication works

In older wireless security configurations, management frames were not always protected against spoofing. An attacker can send forged deauthentication frames that appear to come from the access point or client. A vulnerable client may then disconnect and attempt to reconnect. Repeating the process can create a denial-of-service condition.

2. Controlled Kali Linux simulation

A controlled laboratory test can be performed using an isolated access point and test devices. Aircrack-ng utilities can be used to observe the wireless environment and verify whether management-frame protection is enabled. Wireshark can help identify repeated deauthentication frames and measure the frequency of disconnect events. The test should be stopped after sufficient evidence is collected and should never be performed against public or production networks without explicit authorization.

3. Availability impact

A successful deauthentication attack can cause repeated connection loss, interrupt online classes or business applications and increase support workload. If the attack is sustained, wireless-dependent services may become unavailable to users in the affected area.

4. Mitigation

Use WPA3 and enable Protected Management Frames where supported. For WPA2 networks, enable 802.11w/PMF when available. Wireless IDS/IPS solutions can detect abnormal management-frame activity. Access points and clients should be kept updated. Critical systems should have alternative connectivity where practical. Monitoring should record repeated deauthentication events and identify their source and time.

CONCLUSION

The five case studies show that network, wireless and web application security must be assessed together. Kali Linux provides useful tools for reconnaissance, vulnerability assessment, traffic analysis and controlled validation, but testing must always be performed with authorization. The

strongest protection comes from layered controls including patch management, secure configuration, strong authentication, input validation, network segmentation, encryption, monitoring and regular security testing.

CODE OF CONDUCT

All testing described in this case study is intended for authorized educational laboratories, staging systems and systems for which written permission has been obtained. Testing should be stopped when sufficient evidence has been collected, and no real customer, employee or university data should be modified or exposed.